

Website scanned http://localhost:3000

Date 04 July 2026 · 15:29

0

out of 100

Critical - act now

Overall security posture based on all checks run.

Assessment Scope & Objective

This assessment evaluated the public-facing web presence of **http://localhost:3000** against a set of common, high-impact web security weaknesses. The objective was to give the site owner a clear, prioritized understanding of their current security posture and the practical steps needed to improve it. Testing was non-intrusive and limited to information the site returns to any ordinary visitor.

Executive Summary

Security summary for http://localhost:3000

Overall score: 0/100 (Critical - act now)

Your website has serious security problems that need attention right away.

We found 15 issue(s) to address:

1. [High] Site does NOT use HTTPS

Why it matters: Traffic is unencrypted and can be read or modified by attackers.

2. [High] Exposed: Environment file (.env)

Why it matters: May contain passwords, API keys, and database credentials. Found at /.env.

3. [High] Exposed: Git repository (.git)

Why it matters: Exposes source code and its full history to anyone. Found at /.git/config.

4. [High] Exposed: Backup archive

Why it matters: A downloadable backup can hand over your whole site. Found at /backup.zip.

5. [High] Site is not served over HTTPS

Why it matters: There is no TLS certificate to evaluate because the site is not using HTTPS.

6. [Medium] Missing header: Strict-Transport-Security

Why it matters: Forces browsers to always use HTTPS, preventing downgrade attacks.

7. [Medium] Missing header: Content-Security-Policy

Why it matters: Controls what content can load, preventing many injection attacks.

8. [Medium] Missing header: Referrer-Policy

Why it matters: Controls how much address info leaks when users click links away.

9. [Medium] Exposed: Admin panel

Why it matters: Admin login exposed; a target for password guessing. Found at /admin.

10. [Medium] Exposed: PHP info page

Why it matters: Reveals server configuration details useful to attackers. Found at /phpinfo.php.

11. [Medium] Exposed: Apache server-status

Why it matters: Exposes live server activity and visitor details. Found at /server-status.

12. [Medium] No SPF record found

Why it matters: Without SPF, attackers can more easily send email that appears to come from this domain.

13. [Medium] No DMARC record found

Why it matters: Without DMARC, there are no instructions for rejecting forged emails using this domain.

14. [Low] Exposed: Server config (.htaccess)

Why it matters: Server configuration file should not be directly readable. Found at /.htaccess.

15. [Low] CORS is open to all origins

Why it matters: Any website can read this site's responses. This is only safe if none of the data is sensitive.

What you're already doing right:

- Header present: X-Frame-Options
- Header present: X-Content-Type-Options
- Plain HTTP is not served
- No obvious software version disclosure
- security.txt is present
- No obvious information leakage found

Fix these first (most important at the top):

1. Site does NOT use HTTPS
2. Exposed: Environment file (.env)
3. Exposed: Git repository (.git)

Every issue above is fixable, and you've taken the right first step by checking. Address them one at a time.

Understanding the Severity Ratings

Critical	A weakness that could lead to full compromise; address immediately.
High	A serious weakness that a motivated attacker could exploit; address promptly.
Medium	A meaningful gap that increases risk; should be scheduled for correction.
Low	A minor issue with limited impact; worth tidying up.
Info	An observation or a control already working correctly; no action required.

Issues Found

Severity	Finding	Check
High	Site does NOT use HTTPS	HTTPS & Security Headers
High	Exposed: Environment file (.env)	Security Misconfiguration
High	Exposed: Git repository (.git)	Security Misconfiguration
High	Exposed: Backup archive	Security Misconfiguration
High	Site is not served over HTTPS	TLS & Certificate Quality
Medium	Missing header: Strict-Transport-Security	HTTPS & Security Headers
Medium	Missing header: Content-Security-Policy	HTTPS & Security Headers
Medium	Missing header: Referrer-Policy	HTTPS & Security Headers
Medium	Exposed: Admin panel	Security Misconfiguration
Medium	Exposed: PHP info page	Security Misconfiguration

Severity	Finding	Check
Medium	Exposed: Apache server-status	Security Misconfiguration
Medium	No SPF record found	Email Security Records
Medium	No DMARC record found	Email Security Records
Low	Exposed: Server config (.htaccess)	Security Misconfiguration
Low	CORS is open to all origins	CORS Configuration

What's Working Well

- ✓ Header present: X-Frame-Options
- ✓ Header present: X-Content-Type-Options
- ✓ Plain HTTP is not served
- ✓ No obvious software version disclosure
- ✓ No cookies set on the homepage
- ✓ security.txt is present
- ✓ No obvious information leakage found

How to Fix These Issues

1. Site does NOT use HTTPS

Install an SSL certificate (many hosts offer free ones via Let's Encrypt) and redirect all traffic to HTTPS.

2. Exposed: Environment file (.env)

Block public access to '.env' on your server and move secrets out of the web root immediately.

3. Exposed: Git repository (.git)

Deny web access to the '.git' folder in your server config, or remove it from the web root.

4. Exposed: Backup archive

Remove backup files from the web root and store backups somewhere not publicly reachable.

5. Site is not served over HTTPS

Enable HTTPS with a valid certificate (free options are available via Let's Encrypt).

6. Missing header: Strict-Transport-Security

Ask whoever manages your website to add the 'Strict-Transport-Security' header (a one-line server setting).

7. Missing header: Content-Security-Policy

Add a 'Content-Security-Policy' header. Start in report-only mode so it doesn't break anything, then tighten it.

8. Missing header: Referrer-Policy

Add a 'Referrer-Policy' header, e.g. 'strict-origin-when-cross-origin'.

9. Exposed: Admin panel

Restrict the admin area by IP, add strong login protection, and consider a non-obvious URL.

10. Exposed: PHP info page

Delete the phpinfo.php file from your server - it should never be public.

11. Exposed: Apache server-status

Restrict '/server-status' to localhost only in your Apache configuration.

12. No SPF record found

Publish an SPF TXT record listing your authorized mail servers (e.g. 'v=spf1 include:_spf.yourprovider.com ~all').

13. No DMARC record found

Publish a DMARC TXT record at _dmarc.yourdomain (start with 'v=DMARC1; p=none' to monitor, then tighten).

14. Exposed: Server config (.htaccess)

Ensure your server blocks direct access to '.htaccess' files (most do by default - verify).

15. CORS is open to all origins

If any responses contain private data, restrict CORS to specific trusted origins.

Limitations

This report is based on automated, non-intrusive testing and reflects the state of the site at the time of the scan. It is intended as a practical starting point, not a substitute for a full manual security audit. Automated checks can miss issues that require human judgement, such as business-logic flaws or context-specific weaknesses. The findings should be treated as an input to your wider decisions about security, and re-testing is recommended after any fixes are applied.
